

Clase 220 — Caso completo de respuesta a incidentes end-to-end

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: síntesis de *NIST SP 800-61, The Art of Memory Forensics* e *Intelligence-Driven Incident Response* ⌚ Duración estimada: **150 min** · Nivel: **Experto**

Objetivo

Integrar todo lo aprendido en la parte resolviendo un incidente **de principio a fin**: desde la alerta inicial hasta el informe y las lecciones aprendidas. Este es el proyecto capstone: adquisición, análisis multi-fuente, timeline, contención, erradicación, RCA e informe, ejecutados como un caso real y coherente.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Ejecutar** el ciclo completo PICERL sobre un incidente realista.
- 2. **Correlacionar** evidencia de disco, memoria y red en una sola narrativa.
- 3. **Construir** una super-timeline que sostenga las conclusiones.
- 4. **Contener y erradicar** con preservación de evidencia.
- 5. **Entregar** un informe forense y un post-mortem defendibles.

Temas

#	Tema	Por qué importa
1	Escenario y alcance	Enmarca el caso
2	Triage inicial	Primeras decisiones
3	Adquisición multi-fuente	Disco, RAM, red
4	Análisis correlacionado	Unir las piezas
5	Timeline maestra	Cronología del ataque
6	Contención y erradicación	Detener y limpiar
7	RCA y lecciones	Prevenir recurrencia
8	Informe final	Cerrar con calidad

Definiciones y características

- **Capstone**: proyecto integrador que ejercita todas las competencias. Característica: evalúa el criterio, no solo la técnica.

- **Triage:** evaluación rápida para priorizar y decidir. Característica: define el rumbo con información incompleta.
- **Correlación multi-fuente:** unir disco, memoria y red en una historia. Característica: cada fuente confirma o refuta a las otras.
- **Narrativa del incidente:** relato cronológico y causal del ataque. Característica: debe sostenerse solo con evidencia.
- **IOC/IOA:** indicadores de compromiso/ataque. Característica: alimentan detección y búsqueda retroactiva.
- **Contención con preservación:** frenar sin destruir evidencia. Característica: el equilibrio central de DFIR.
- **Cierre:** declaración formal de incidente resuelto. Característica: exige criterios objetivos cumplidos.

Herramientas y preparación

- **Todo el arsenal de la parte:** FTK Imager/ewfacquire, Volatility 3, The Sleuth Kit/Autopsy, plaso/Timesketch, Wireshark/Zeek, Eric Zimmerman's Tools.
- **Escenario:** móntalo tú en un laboratorio aislado de VMs propias, o usa un dataset de entrenamiento DFIR público.
- **Recuerda:** cualquier malware se maneja solo en laboratorio aislado y desechable, con snapshots.

Laboratorio guiado

Escenario propuesto: una estación Windows generó una alerta EDR de PowerShell ofuscado que contactó una IP externa; sospechas de intrusión con exfiltración. Reprodúcelo en tu laboratorio propio.

1. **Triage e identificación:** revisa la alerta, clasifica severidad (clase 202) y define el alcance inicial. Decide aislar por red preservando RAM (clase 216).
2. **Adquisición:** - Volca la RAM (WinPmem) y el disco (FTK Imager → E01), con hashes y cadena de custodia (clases 201, 203, 207). - Captura tráfico si el atacante sigue activo (clase 208).
3. **Análisis de memoria:** con Volatility 3 halla el proceso malicioso, su inyección y su conexión C2:

```
bash vol -f memoria.raw windows.malfind vol -f memoria.raw windows.netscan vol -f memoria.raw windows.cmdline
```

4. **Análisis de disco:** en Autopsy/TSK examina artefactos de ejecución y persistencia (clases 204, 205): Prefetch, ShimCache/AmCache, tareas programadas, claves Run.
5. **Análisis de red:** en Zeek/Wireshark confirma el C2, el beaconing y qué se exfiltró (clase 208).
6. **Timeline maestra:** con plaso genera la super-timeline y reconstruye la secuencia entrada → ejecución → persistencia → movimiento → exfiltración (clase 209).
7. **Contención y erradicación:** enumera toda la persistencia, elimínala, rota credenciales y valida la erradicación (clase 216).
8. **RCA e informe:** aplica 5 Porqués e Ishikawa (clase 217) y redacta el informe forense y el post-mortem blameless (clases 217, 218).

Ejercicios

1. Escribe la decisión de triage y su justificación de severidad.

2. Correlaciona un hallazgo de memoria con uno de disco y uno de red.
3. Construye la timeline maestra con al menos ocho eventos.
4. Enumera toda la persistencia del atacante en el caso.
5. Deriva cinco IOCs del incidente para búsqueda retroactiva.
6. Formula tres acciones correctivas contra causas raíz.

Reto verificable

Resuelve el incidente completo y entrega el paquete final: cadena de custodia, hallazgos de memoria/disco/red correlacionados, timeline maestra, plan de contención/erradicación ejecutado, RCA e informe forense con versión ejecutiva.

Criterio de aceptación: la narrativa del ataque está respaldada por evidencia de las tres fuentes (memoria, disco, red) que concuerdan entre sí; la timeline maestra tiene al menos ocho eventos fechados en UTC; el informe permite reproducir el análisis; y las acciones correctivas atacan causas raíz, no síntomas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Conclusiones sin respaldo	Una sola fuente. Corroborar con memoria, disco y red.
Perdiste la RAM	Contuviste apagando. Aísla por red primero.
Timeline caótica	No la acotaste ni pivoteaste. Filtra por ventana y parte de eventos conocidos.
Erradicación incompleta	Persistencia sin enumerar. Revísala toda antes de cerrar.
Informe no reproducible	Faltan hashes/versiones. Documenta la metodología completa.

Preguntas frecuentes

¿Por dónde empiezo un caso real? Por el triage: entiende la alerta, acota el alcance y decide contención preservando evidencia. Luego adquieres antes de analizar.

¿Qué fuente analizo primero? Sigue el orden de volatilidad: memoria y red en vivo primero, disco después. Pero correlaciona las tres al final.

¿Cómo sé que terminé? Cuando la narrativa se sostiene con evidencia concordante, la persistencia está erradicada y validada, y el informe permite a un tercero reproducir el análisis.

¿Y si el laboratorio tiene malware real? Manéjalo solo en VMs aisladas y desechables, con snapshots, sin salida a Internet salvo la controlada para observar el C2.

Referencias

- NIST SP 800-61 Rev. 2: <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- Ligh, Case, Levy, Walters — *The Art of Memory Forensics*, Wiley 2014.
- Roberts & Brown — *Intelligence-Driven Incident Response*, O'Reilly 2017.
- Autopsy / The Sleuth Kit: <https://www.autopsy.com/>

Siguiente clase

Clase 221 - Fundamentos de seguridad en la nube y responsabilidad compartida